Koban — Access Controls Policy

Owner: Vishhvak Srinivasan (sole operator and security contact) **Effective:** 2026-07-06 · **Review cadence:** every 6 months, jointly with the Information Security Policy **Scope:** all production assets and sensitive data of the Koban personal-finance application: the Railway project (web service, PostgreSQL database, service variables), the production domain `finances.vishhvak.com`, the GitHub repository, financial data-provider accounts (Plaid, Teller, SnapTrade, SimpleFIN), the domain registrar, and the operator workstation.

Koban is a single-operator system. The operator is the only administrator and the only end user. This policy states the controls as they are actually practiced.

1. Principles

- **Least privilege by construction.** Exactly one human identity exists per system; no shared, service-shared, or secondary human accounts are created. Machine access uses scoped tokens (e.g., a project-scoped Railway token) rather than account-wide credentials wherever the platform offers them.
- **Read-only financial access.** All data-provider connections are provisioned read-only (Plaid Link read scopes, Teller, SnapTrade read connections, the SimpleFIN read-only protocol). No credential held by the system can move money.
- **No standing plaintext secrets in code.** Credentials exist only in the git-ignored local `.env` and in Railway service variables. Version control carries variable names only.

2. Authentication requirements

System	Control
Application (hosted mode)	Better Auth session required for the web UI and `/api/*`; registration closes after the first (owner) account. Passkey (WebAuthn, phishing-resistant) and TOTP second factors supported; when a second factor is enrolled, password-only sign-in does not grant a session.
Application API (programmatic)	Better Auth session, Better Auth API key, or instance bearer token; unauthenticated requests rejected in hosted mode.
GitHub, Railway, Plaid, Teller, SnapTrade, SimpleFIN, registrar	Individual operator account with multi-factor authentication enabled.
Production database	Not exposed publicly; reachable through the Railway project only. Credentials live in Railway service variables.
Operator workstation	Full-disk encryption (FileVault) enabled; OS automatic security updates enabled; local login required.

3. Authorization model

- There is a single role: **owner-operator**, holding administrative rights across all in-scope systems. Role-based segregation is not applicable to a one-person system and is deliberately not simulated.
- Third parties are never granted accounts, API keys, or OAuth grants to production systems. Any tooling access (e.g., CI) uses repository-scoped, non-human credentials with the minimum scope the platform allows.

4. Access provisioning and revocation

- **Provisioning:** adding any new account, token, API key, or OAuth grant to an in-scope system is itself a security-relevant change and is recorded (commit, or dated note in `docs/security/`).
- **Revocation:** credentials suspected of exposure are rotated immediately at their source (see the Information Security Policy, Incident Response). Provider items can be disconnected at each provider's dashboard at any time; the application's data can be fully deleted via the in-app reset.

- **Periodic review:** at each policy review the operator enumerates active credentials — Railway tokens, GitHub keys/OAuth apps, provider API keys and connected items, database credentials — and revokes anything stale or unrecognized.

5. Session and transport controls

- All production access (browser and API) is over HTTPS/TLS terminated at the Railway edge; no plaintext listener exists on the public internet.
- Application sessions are managed by Better Auth with its default secure cookie handling; the auth secret is a high-entropy value stored as a service variable.

6. Exceptions

Any deviation from this policy is documented as a dated note in `docs/security/` with rationale and an expiry, and is revisited at the next review. As of the effective date there are no exceptions.